

CSCE 701 CYBERSECURITY · MODULE 12 · LECTURE NOTES

Measuring Security

Why it is hard, and which metrics mislead.

MODULE OUTCOMES

- Explain why security resists measurement.
- Identify metrics that mislead and say how.
- Choose metrics that drive useful behaviour.
- Explain risk quantification and its limits.
- Explain the incentive problems around security spending.

1 Why security resists measurement

THE THING YOU WANT TO MEASURE IS THE ABSENCE OF SOMETHING

'Secure' means 'no successful attack has occurred' — and a quiet year is entirely consistent with excellent security and with having been compromised and not noticed (Module 01 §1's second row, and Module 09's whole subject).

So the outcome you care about is unobservable in the good case, which is unlike almost every other engineering property: performance, availability, and correctness all produce observable evidence when they are good.

And the base rate is low. Severe incidents are rare for any single organisation, so there is no statistical signal available in your own history — two good years tells you almost nothing, and the sample will never grow large enough.

Which leaves process and control metrics as proxies — and a proxy that is managed becomes a target, which is §2's table and is the central hazard of this module: the measurement does not merely fail to capture security, it actively distorts the behaviour it is meant to assess.

Metric	What it actually rewards	The distortion
Number of open vulnerabilities	Not looking.	Scanning less, or scanning fewer systems, improves the number — and so does classifying findings as informational.
Patch compliance percentage	Patching the easy majority of the fleet.	The hard 5% is precisely where the risk lives — the legacy system nobody can reboot — and 95% compliance is compatible with total exposure.

Metric	What it actually rewards	The distortion
Training completion percentage	Clicking through the module.	It measures attendance rather than behaviour, and the correlation between the two is weak (Module 11 §2).
Phishing simulation click rate	Punishing the people who click.	Which suppresses reporting (Module 11 §2) and makes the organisation less safe while the metric improves.
Number of security controls deployed	Adding controls.	Which spends the compliance budget (Module 11 §1) and can reduce actual compliance with the controls that matter.
Alerts handled per analyst	Noisy detection rules.	It rewards exactly the volume problem that makes detection programmes fail (Module 09 §3).

Every row is an instance of Goodhart's law — a measure adopted as a target ceases to measure what it measured — and the value of the table is that it names the *specific* distortion each metric produces, which is what lets you predict the behaviour before you deploy the metric rather than after.

2 Better metrics

- **Time from advisory publication to patched in production**, reported at the median *and* the 95th percentile — **the tail is where the risk is** (Module 08 §4), and a good median with a terrible tail is the common and dangerous shape.
- **Mean time to detect, measured against deliberately injected test events** — **which is measurable continuously without waiting for a real incident**, and it tests the whole chain from log to alert to person (Module 09 §2).
- **Percentage of accounts on origin-bound second factors** — **a specific, high-value, countable control** whose improvement is genuinely an improvement (Module 02 §1), unlike a count of controls in general.
- **Inventory query time** — **'can you locate every deployment of a given library version in under five minutes' is a real capability test** (Module 08 §3) and is the metric that would have distinguished organisations during the major logging advisory.
- **And tabletop exercise findings closed**, which measures whether learning turns into change (Module 10 §4) rather than into documents. **Each of these measures a *capability* rather than a count**, and **each is hard to improve without actually improving**.

PREFER METRICS YOU CANNOT IMPROVE WITHOUT IMPROVING

Ask of every candidate metric: what is the cheapest way to improve this number *without* improving security? Five minutes of adversarial thinking per metric.

If there is a cheap way, the metric will be gamed — not through dishonesty, but because people reasonably optimise what is measured and rewarded, and that is what you asked for. Treating the resulting behaviour as a failure of integrity is a misdiagnosis.

And prefer measured capabilities over counted artefacts: 'we detected the injected event in four minutes' cannot meaningfully be faked, and 'we have forty detection rules' can be improved by writing a forty-first that fires on nothing.

Which is CSCE 633 Module 12's choose-the-metric-from-the-use discipline and CSCE 642 Module 12's honest reporting, arriving in the subject where the incentive to look good is strongest (§4) and the ability to check is weakest (§1).

3 Risk

RISK QUANTIFICATION IS USEFUL FOR COMPARISON AND NOT FOR ABSOLUTE NUMBERS

Expected loss is probability times impact — and for a rare event you have essentially no data on the probability, so the first factor is an estimate with very wide uncertainty.

So an absolute figure is a guess with decimal places attached, and presenting it as a measurement is misleading in a way that a stated range with its assumptions is not — the number acquires authority it has not earned the moment it enters a spreadsheet.

But *comparative* estimates are genuinely useful: 'this risk is roughly ten times that one' is defensible from far weaker evidence, and it is enough to order a budget — which is what the exercise is actually for. Ordering does not require calibration; magnitude does.

And the discipline of estimating is valuable even when the resulting number is not — it forces the assumptions to be written down explicitly, and an explicit assumption can be argued with and tested (CSCE 669 Module 12 §4's sensitivity analysis, which is the right follow-up to any risk figure).

4 Incentives

- Security spending is invisible when it works, so it competes badly against features, which are visible — and the competition is for the same budget and the same engineering time.
- The person who bears the cost of a control is frequently not the person who bears the risk of its absence — which is the externality at the centre of Anderson's security-economics argument, and it explains a great deal that looks like irrationality.
- Compliance is measurable and security is not (§1), so budgets flow to compliance — and a fully compliant system can be insecure, which is not a criticism of any particular standard but a consequence of what can be audited.
- And a prevented incident produces no evidence at all, so the team that quietly prevents incidents looks idle beside the team that responds visibly and well to them — which is a career incentive pointing the wrong way.
- Which is precisely why §2's capability metrics matter — they give the invisible work something visible to point at, which is their organisational function quite apart from their measurement value. The externality is the deepest of these problems: a vendor's insecure default costs its users and not the vendor, which is why Module 11 §3's defaults needed regulation to change in several cases rather than changing on their own.

WHAT TO DO ABOUT MEASUREMENT

Pick a small number of capability metrics (§2) and track them over time — five is better than fifty, because fifty cannot be acted on and will include several from §1's table.

State explicitly what they do not measure, so that **the dashboard is not mistaken for coverage** — which is the specific failure of a security dashboard: it makes the measured portion look like the whole.

Test capabilities rather than counting artefacts — injected detection events, tabletop exercises, timed inventory queries, and executed credential rotations, all of which resist gaming because the only way to pass is to work.

And report the threats you have accepted (Module 01 §2's fourth option) **alongside the controls you have implemented** — **which is the single piece of reporting that conveys the actual position,** and it is the one almost never included, because a list of accepted risks reads as an admission rather than as a decision.

Where to see this taught differently

Original material only goes so far — hearing the same idea in another voice is how it sticks. These are free, and they cover this module specifically.

Resource	What it covers for this module
Anderson — Security Engineering, the economics chapter (free PDF)	§4's incentive problems, developed properly — and the externality argument is the most important idea in this module.
Hubbard & Seiersen — How to Measure Anything in Cybersecurity Risk	§3's case for quantification , argued at length — read alongside this module's caveat about absolute figures. Library copy.
Verizon DBIR and the Cyentia reports (free)	The nearest thing to population-level data — which is what individual organisations lack (§1).
Goodhart, and Muller — The Tyranny of Metrics	§1's table as a general phenomenon — the same distortion documented across medicine, education, and policing.

Exercises

Do these in code, not on paper, unless the exercise says otherwise. The module is not finished until they run.

- 1 List the security metrics your organisation reports** and classify each against §1's table.
- 2 For each, name the cheapest way to improve it without improving security.**
- 3 Propose five capability metrics** from §2 and say what each would cost to collect.
- 4 Measure your time to detect** with an injected event.

- 5 **Measure your inventory query time** for a specific library version.
- 6 **Measure your patch time at the median and the 95th percentile**, and report the gap.
- 7 **Produce a comparative risk ranking** for five threats, with the assumptions written down.
- 8 **Vary your least-confident assumption** and report whether the ranking changes.
- 9 **Identify one externality** in your own system — a cost you impose on someone else.
- 10 **Write your accepted-risk list** and put it next to your control list.

Self-check

Answer these in writing, from memory, without looking back at the notes. If you cannot, you have read this module but not yet learned it — that is useful information, not a failure.

- 1 Why does security resist measurement, and what does a quiet year mean?
- 2 Why is there no statistical signal in your own history?
- 3 Give six misleading metrics and the distortion each produces.
- 4 What law are they all instances of?
- 5 Give five better metrics and what they have in common.
- 6 State the selection criterion for a metric.
- 7 What is risk quantification good for, and not good for?
- 8 Why is the estimating discipline worth more than the number?
- 9 Name four incentive problems and say which is deepest.
- 10 Give four things to do about measurement.